



INGENIERÍA DE SEGURIDAD US
Avda. Reina Mercedes s/n. 41012
Sevilla



Consulta Individual 2.

CONFIDENCIALIDAD E INTEGRIDAD EN LA TRANSMISIÓN SEGURA.

RESUMEN EJECUTIVO

- Se ha diseñado una **estrategia integral de ciberseguridad** para garantizar la confidencialidad e integridad de datos médicos en tránsito y almacenamiento, cumpliendo con HIPAA, GDPR e ISO 27001. Las soluciones implementadas son la protección de datos en tránsito mediante AES-256-GCM para información crítica, una configuración TLS optimizada con exclusión de protocolos vulnerables, defensas contra amenazas digitales, además de la optimización de navegadores corporativos.

Consulta 2.1: Alternativas de descifrado y verificación de la integridad

1. TEXTO CIFRADO → MAC → VERIFICAR → DESCIFRAR → **EtM**

Primero se cifra el texto plano, luego se calcula el MAC (Message Authentication Code) sobre el texto cifrado. Al recibir el mensaje, se verifica el MAC para garantizar la integridad. Por último, el texto se descifra.

2. TEXTO CIFRADO → DESCIFRAR → HASHING SEGURO → VERIFICAR → **E&M**

El proceso comienza calculando un hash (MAC) sobre el texto plano. Luego, el texto plano y el MAC se cifran juntos. Una vez que el mensaje se ha recibido, este se descifra y se verifica la integridad utilizando el MAC.

3. TEXTO CIFRADO → VERIFICAR → DESCIFRAR → MAC → **MtE**

Primero, se calcula el MAC sobre el texto plano. Se cifran juntos el texto plano y el MAC. Al recibir el mensaje, se verifica la integridad del MAC y luego se descifra el texto.

Consulta 2.2: Comparación de seguridad y eficiencia de las alternativas de AEAD

ALTERNATIVA	SEGURIDAD	EFICIENCIA
EtM (Encryption then MAC)	<u>A favor:</u> Verificación de integridad después del cifrado. Alta seguridad si el MAC y el cifrado son robustos. <u>En contra:</u> Verificación de integridad después de cifrar el texto puede ser menos eficiente.	<u>A favor:</u> Menor sobrecarga, se cifra primero y luego se aplica el MAC. <u>En contra:</u> El proceso de cifrado seguido de MAC puede ser menos eficiente que otras opciones.
E&M (Encryption & MAC)	<u>A favor:</u> La integridad se verifica antes del cifrado, aumentando la seguridad. <u>En contra:</u> El cálculo del MAC y posterior cifrado añade una sobrecarga.	<u>A favor:</u> MAC se calcula antes de cifrar, lo que puede optimizar la verificación de la integridad al recibir el mensaje. <u>En contra:</u> Menor eficiencia por la necesidad de calcular el MAC y luego cifrar.
MtE (MAC then Encryption)	<u>A favor:</u> La integridad se verifica antes del cifrado, aumentando la seguridad. <u>En contra:</u> El cálculo del MAC y posterior cifrado añade una sobrecarga.	<u>A favor:</u> Verificación rápida de la integridad al recibir el mensaje. <u>En contra:</u> Más recursos y tiempo de procesamiento comparado con EtM.

Consulta 2.3: Recomendación de cipher-suite más segura y eficiente

El objetivo es garantizar que la información confidencial de los clientes se transmita de forma segura, íntegra y eficiente.

Evaluamos las mejores opciones de cifrado (cipher-suites) según sus criterios:

- Confidencialidad → Evitar que terceros puedan leer los datos.
- Integridad → Asegurar que los datos no se modifiquen en su tránsito.
- Rendimiento → Velocidad de cifrado/descifrado.

Para ponderar estos criterios y comparar opciones utilizamos el método de Multicriteria Decision Making (MCDM).

- **Confidencialidad** (60.42%)
- **Integridad** (24.46%)
- **Tiempo de cifrado** (5.37%)
- **Tiempo de descifrado** (9.75%)

Una vez que hemos analizado los criterios utilizando la matriz normalizada y el vector de prioridad asignando sus pesos de acuerdo con cada criterio, el algoritmo de cifrado que más se adecua a ellos es:

Cipher-Suite Recomendada: **TLS_AES_256_GCM_SHA384**

¿Por qué?

AES-256 proporciona máxima seguridad para datos sensibles, este tipo de algoritmo es usado para transferencias internacionales, protección de historiales médicos, etc...

GCM (Galois/Counter Mode) es el más recomendado pues cifra y autentica los datos en un solo paso evitando manipulaciones. Protege contra replay attacks y eficiente en hardware.

Por último, SHA-384 es el seleccionado pues proporciona mayor seguridad que SHA-256 (es más difícil de romper).

Esta Cipher-Suite es ideal para el sector de la salud ya que cumple con regulaciones rigurosas, protege información crítica y reduce riesgos legales.

Sin embargo, una alternativa rápida si hubiera cuellos de botella en rendimiento sería **TLS_CHACHA20_POLY1305_SHA256**, esta opción de cifrado se encuentra optimizada para dispositivos sin hardware limitado como un móvil, además de tener una seguridad similar a AES-128 (suficiente para la mayoría de los casos).

Consulta 2.4: Configuración de navegadores

Para conseguir la configuración de dichos navegadores (Mozilla Firefox y Microsoft Edge), admitiendo únicamente los cipher-suite más eficientes y seguros que anteriormente hemos seleccionado, hay que seguir una serie de pasos:

Cualquier Empleado puede seguir estos pasos en su ordenador:

Mozilla Firefox

- Acceder a la configuración manual: escribir en la barra de direcciones (**about:config**) y aceptar la advertencia de riesgo.
- Modificar los parámetros necesarios.
 - Fuerza TLS 1.3 (la versión más segura),
 - security.tls.version.min = 4,
 - Deshabilita cifrados obsoletos: security.ssl3.dhe_rsa_aes_256_sha=false, security.ssl3.ecdhe_ecdsa_aes_128_sha = false

Microsoft Edge

- Forma rápida: ejecutar en el navegador
(msedge.exe--cipher-suite-blacklist=0x009E,0xCCA9,0x1301 --ssl-version-min=tls1.3)
- Configuración permanente: En el icono de Edge pulsar el clic derecho y seleccionar “Propiedades”, editar el campo “Destino” con una ruta (ej: "C:\...\chrome.exe" --cipher-suite-blacklist=0x009E,0xCCA9 --ssl-version-min=tls1.3), finalmente hacer clic en aceptar y reiniciar el navegador.

Configuración Empresarial, solo el departamento encargado puede utilizarlo:

Mozilla Firefox

- En la carpeta de instalación crear un archivo **policies.json**, añadiendo la versión TLS y los cipher-suites correspondientes.

Microsoft Edge

- Abrir el editor de políticas en Windows: Escribir (gpedit.msc) y navega hacia (Configuración del equipo > Plantillas administrativas > Microsoft Edge).
- Buscar la lista de cifrados permitidos: Seleccionar “Habilitado” y en opciones buscar las seleccionadas (TLS_AES_256_GCM_SHA384,TLS_CHACHA20_POLY1305_SHA256).
- Buscar la versión mínima de SSL: De nuevo “Habilitar” y en opciones escribir (tls1.3).
- Finalmente, después de reiniciar el servidor se aplican los cambios instantáneamente en los PCs conectados y los empleados no podrán modificar estas configuraciones.

Protección contra Clickjacking

El objetivo es evitar que estos navegadores sean atacados, bloqueando iframes maliciosos. Estos ataques engañan a los empleados para que hagan clic en elementos

falsos (como botones invisibles en las páginas donde tienen que acceder), esto podría llevar a la aseguradora a no tener acceso a historiales médicos o al robo de credenciales de acceso.

Las extensiones recomendadas para evitar estos engaños son:

- uBlock Origin → filtra elementos sospechosos.
- NoScript → Permite scripts solo de sitios autorizados.

Su instalación es sencilla y segura.

Gestión de Certificados de Confianza

Para revisar los certificados digitales cualificados que un navegador puede confiar:

- Firefox: (about:preferences#privacy) → "Ver certificados" → Pestaña "Autoridades"
- Microsoft Edge: (Edge://settings/security) → "Administrar certificados"

Para eliminar una entidad no fiable partiendo de lo anterior, es tan sencillo como buscar la CA sospechosa y hacer clic en "Eliminar/Desconfiar". Algunos sitios dejarán de funcionar si dependen de ella.

Verificación General de seguridad

Esto es crucial para asegurarnos que los datos viajan cifrados correctamente, no hay fugas de información y conocer que el navegador no tiene vulnerabilidades.

Las herramientas claves son: SSL Labs Client Test y Browserleaks.